

Red Team Report – Cliente F.L. – Consulenza Etica e Analisi Tecnica (Aprile–Maggio 2025)

Questo rapporto dettaglia le attività di Red Teaming svolte per il cliente F.L., un operatore e-commerce su piattaforma Etsy. L'intervento si è concentrato su un'analisi approfondita della rete domestica e delle abitudini digitali del cliente per individuare vulnerabilità tecniche e umane. La consulenza, condotta in ambiente reale tra aprile e maggio 2025, fornisce indicazioni dettagliate per migliorare la postura di sicurezza attraverso tecniche di penetrazione etica, simulazioni di attacco e formazione.

- Obiettivi e Ambito dell'Attività

L'attività di Red Team ha avuto come scopo principale l'identificazione e l'analisi delle possibili vulnerabilità nella rete domestica del cliente e nei suoi comportamenti digitali. I test sono stati eseguiti in un contesto autorizzato e controllato, garantendo la sicurezza operativa durante tutto il processo.

- Analisi passiva e attiva sulla rete domestica per mappatura e ricognizione

- Tentativi di penetrazione autorizzata sulla macchina target principale, un sistema Windows 10

- Simulazione di attacco phishing etico per valutare il rischio sociale

- Educazione e formazione su pratiche di anonimato, uso di VPN, ambienti virtualizzati e difesa informatica

Questa combinazione di valutazioni tecniche e comportamentali ha permesso di individuare le aree più critiche da mitigare per la sicurezza complessiva.

Setup Tecnico e Strumentazione

La fase tecnica ha impiegato una piattaforma Kali Linux 2023.4 in modalità bridge tramite VirtualBox, per mimare un ambiente di attacco realistico. La rete target è stata analizzata con un focus su tutta la subnet 192.168.1.0/24, condotta con strumenti di scansione e analisi avanzati.

Strumenti utilizzati: nmap, arp-scan, netdiscover, Wireshark, e Thunderbird per test di social engineering

- **Identificazione dei MAC vendor tramite arp-scan per mappare i dispositivi connessi**

- **Ambiente operativo virtualizzato garantito da Kali Linux per simulazioni realistiche**

- **Subnet target osservata e analizzata per individuare dispositivi e potenziali risorse vulnerabili**

Questi presupposti tecnici hanno creato le basi per una ricognizione completa e una simulazione di attacco efficace.

Enumerazione della Rete e Ricognizione

Attraverso scansioni ARP, sono stati identificati quattro host attivi all'interno della rete target:

- Indirizzo .1: Gateway Router ZTE TIM

- Indirizzo .3: Dispositivo non riconosciuto denominato "Arkadian"

- Indirizzo .13: PC target con sistema Windows 10

- Indirizzo .11: Macchina Kali dell'operatore Red Team

Tutti i dispositivi, tranne Kali, risultavano silenti alle scansioni ICMP e alle scansioni TCP tradizionali, suggerendo la presenza di un firewall host-based attivo in modalità drop silenzioso, presumibilmente Windows Defender. Questa configurazione limita significativamente la superficie di attacco via rete aperta.

La riconoscenza ha quindi confermato un ambiente di rete con solide misure difensive di base, necessitando approcci più sofisticati e social engineering per la compromissione.

Scansioni Nmap e Risultati Tecnici

Le scansioni sono state orchestrate per massimizzare la raccolta di informazioni pur mantenendo un profilo di bassa rumorosità e indiscutibilità:

- SYN stealth scans (-sS) con opzione -Pn per saltare l'ICMP

- Firewall scans (-sF, -sN, -sX) per sondare regole firewall

- Pacchetti frammentati (-f) per eludere alcuni sistemi di rilevamento

- Scansioni TCP connect per la totalità delle porte (-p-)

- Scansioni UDP sulle 50 porte più comuni (-sU --top-ports 50)

- Scan aggressivo (-A) per fingerprinting SO e rilevamento servizi

Non è stata rilevata alcuna porta aperta sulla macchina target, confermando un firewall locale configurato efficacemente per bloccare tutte le connessioni in entrata. Questi risultati indicano una postura di sicurezza tecnica di base ma solida, limitando attacchi a vettori non convenzionali o sociali.

Simulazione di Attacco Phishing Etico

Come test comportamentale, è stato predisposto e inviato un messaggio e-mail simulato contenente un link camuffato da "[clicca qui](#)". Tale link conduceva a un'immagine con un messaggio etico volto a far riflettere sul rischio di attacchi reali.

Il cliente ha cliccato il link dimostrando, con l'azione, la vulnerabilità alla tecnica di social engineering. Questo risultato evidenzia come il fattore umano rappresenti, a oggi, la maggiore superficie d'attacco e rimane un punto critico da mitigare con formazione e strumenti tecnologici.

Questo test ha rappresentato una componente cruciale del report, delineando un'area critica per la futura strategia di difesa.

Educazione, Raccomandazioni e Miglioramenti Proposti

A conclusione dell'attività sono state fornite indicazioni dettagliate per migliorare la sicurezza complessiva del cliente. Le raccomandazioni comprendono:

- Uso di VPN personali per cifrare il traffico e proteggere la navigazione anche su

reti fidate

- Implementazione di ambienti virtualizzati (VirtualBox) per operazioni sperimentali o lavorative separate dal sistema principale
- Utilizzo di password manager per gestire credenziali in modo sicuro
- Impiego di DNS filtrati per bloccare domini malevoli
- Segmentazione della rete domestica per isolare dispositivi IoT e ridurre rischi di compromissione
- Formazione su riconoscimento e gestione di e-mail potenzialmente pericolose, incluso disabilitare la visualizzazione HTML automatica in client di posta come Thunderbird

Questi accorgimenti sono fondamentali per elevare la difesa multilivello e ridurre efficacemente il rischio di compromissione attraverso vettori tecnici e comportamentali.

Conclusioni e Valutazione Complessiva

L'attività di **Red Team** ha messo in evidenza un sistema tecnico ben configurato per la sicurezza di base, con un firewall host-based efficace e nessuna porta aperta visibile all'esterno. Tuttavia, il rischio principale emerge dal fattore umano, dimostrato dalla facilità di "acchiappare" il cliente con una simulazione di phishing.

Il cliente ha dimostrato un'ottima disponibilità e interesse ad adottare le pratiche e i suggerimenti proposti, elemento essenziale per il rafforzamento nel medio-lungo termine.

Si raccomanda di implementare con priorità le misure di educazione, segmentazione e uso di VPN e ambienti virtualizzati, per ridurre sia la superficie tecnica sia quella umana di attacco.